Catalogizer v2.4.3 release notes

Pre-release, NOT production-ready. Release gate state: `BLOCKED-NO-BASELINE` (no live run on connected hardware and no v2.4.2 baseline run exist; the full-suite retest, manual QA and live UI QA have not been run). Everything labelled PROVISIONAL landed on `main` and counts as done for planning but is not verified. This file carries the same content as `docs/CHANGELOG.md` section `[2.4.3]` in release-notes form for GitHub/GitLab release pages; the verification jobs for every PROVISIONAL group are scheduled in `docs/PROVISIONAL_VERIFICATION_PLAN.md` section 6 (due dates proposed by the release preparer, adjustable by the operator). Upgrade steps: see "Behaviour changes and upgrade notes" below and `docs/UPGRADE_NOTES.md`. Credentials and private hosts are not part of these notes.

Release class: **pre-release** (provisional-eligible, constitution 11.4.290(G)). Prepared on branch `release/v2.4.3-prep` from `main` `b43f5370` (328 commits since the `v2.4.2` tag; the annotated tag object is `26f2e1df` and its commit is `fc8dcf27e`; `git log v2.4.2..b43f5370`). Not tagged, not published. Versioning is SemVer. Version files bumped to 2.4.3: `versions.json` (global 2.4.3), `docs/api/openapi.yaml`, `catalog-web`, `catalogizer-desktop` and `installer-wizard` (package.json, package-lock.json, tauri.conf.json, Cargo.toml), Android `versionName` 2.4.3 / `versionCode` 9 (was 8), Android TV `versionName` 2.4.3 / `versionCode` 11 (was 10), the two Android `CLAUDE.md` version lines, the installer-wizard AppImage file name in `challenges/scripts/desktop_appimage_launch_challenge.sh`, and the version mentions in `README.md`, `docs/CONTRIBUTING.md` and `docs/DEPLOYMENT_GUIDE.md`.

Release gate (constitution 11.4.298, stated first)

- **Gate state: `BLOCKED-NO-BASELINE`.** No 11.4.298 live run of the whole suite on connected target hardware has been done for this build, and no baseline run of v2.4.2 exists, so no 11.4.293 comparison (`NO-WORSE-PROVEN`) is possible. The live baseline run (flash/run v2.4.2, run the suite, then the same on v2.4.3) is **owed**. This is a labelled pre-release; it must not be deployed to users or called production-ready. The comparator and gate tools (`image_no_worse`, `release_gate`, CAT-WP03-MECH) are gate-logic unit class and are not wired into tagging or deploy.
- **The full-suite retest of the tag (11.4.40), the 11.4.185 manual QA and the live UI QA have NOT been run on this candidate.** The release-consistency checker is **advisory** for v2.4.3 (blocking for v2.5.0, see `docs/release/V2_5_0_GATE_CHECKLIST.md`, an unreviewed draft).

State summary by label (11.4.290(G))

Counts (11.4.290(4)): **V counts evidence sets, P counts items, so they are not comparable.** V = 3 evidence sets whose hashes verify (1 checker-cited, 2 hand-verified; the behaviour they back is PROVISIONAL). P = 47 distinct `Roadmap-Item` ids, derived with `git log v2.4.2..b43f5370 --format='%(trailers:key=Roadmap-Item,valueonly,separator=%x2C)'`, split on commas and spaces, then `sort -u | wc -l`; of the 328 commits in the range (75 merges), 286 carry a `Roadmap-Item:` trailer and 42 carry none (merges and some docs commits; the items they merge are counted through their own commits). Sub-ids named in the lines below (PX-F1..F23, PW-F1..F10 and so on) belong to those ids or to the groups that contain them and are not counted separately. R = 0 reopened, O = 0 new overdue (the carried OVERDUE jobs below remain).

VERIFIED (committed machine evidence, checked while preparing this entry)

Checked on this branch with `sha256sum -c` (0 non-OK lines). "VERIFIED" here means the evidence set exists and its hashes verify, not that the behaviour is verified.

- `docs/qa/img-slim/` (CAT-IMG-SLIM-1 minimal-ffmpeg image evidence; `SHA256SUMS.txt` verifies). Container class; the full `catalog-api/Dockerfile` build including the Go stage was not exercised.
- Carried from 2.4.2 and earlier, not re-run: the VERIFIED rows of `[2.4.2]`, `[2.4.1]`, `[2.4.0]`. Caveat carried with them: the cover-art SSRF live-test evidence set (the coverart results/final directory under docs/qa) has a `SHA256SUMS.txt` that FAILs `sha256sum -c`; this is the checker's known `sha_fail=1` under `--section 2.4.2` (see the checker bullet below).
- Other evidence directories added since v2.4.2 (`docs/qa/login-lock-2-round*`, `chpw-rl-2-round*`, `sec-ws-1*`, `favr3-fu*`, `stack3`) carry no checkable hash manifest and are treated as PROVISIONAL.

Hand-verified evidence sets (not checker-cited)

Checked with `sha256sum -c` (0 non-OK lines) by hand. They are not cited as backticked paths because the checker would list their unhashed README.html and README.pdf twins as UNLISTED. The behaviour they back stays PROVISIONAL.

- docs/qa/anton-smb-n3-20261112/run1.log, run2.log, run3.log and README.md there (Anton SMB N=3 live run; SHA256SUMS verifies). No negative control: the run proves reachability at N=3 only.
- docs/qa/secq2-repro-20261112/rep6.json and rep6.log.txt (CAT-SECQ2-WD-F1 live WebDAV reproduction: not reproduced, 6/6 ok; SHA256SUMS verifies).

PROVISIONAL (landed on `main`; counts as done for planning, NOT verified)

Each item landed after an Opus review that returned GO-with-follow-ups (minor-class follow-ups tracked in `docs/FOLLOW_UPS_NEXT_PHASE.md`). Evidence class is mostly unit / httptest / SQLite (some PostgreSQL 15/16, container) level; live end-to-end runs are owed. **Verification jobs (11.4.290(1)):** `docs/PROVISIONAL_VERIFICATION_PLAN.md` section 6 schedules one job per group below, `VJ243-01..VJ243-23`, each with its target, the existing command (or `command: owed (no automated check yet)`, registered as gap `G243-n`), the evidence class needed for VERIFIED and a due date. Group to job: authentication and sessions VJ243-01..06; `/ws` VJ243-07; egress and storage hosts VJ243-08, 11, 12; error leakage and redaction VJ243-09; confinement VJ243-10; wizard VJ243-13; web VJ243-14; release tooling VJ243-15..18; image VJ243-19; stale tests VJ243-20; docs VJ243-21; research and records VJ243-22; whole release VJ243-23. **Due dates are proposed by the release preparer; the operator may adjust them:** host jobs 2026-11-21, runtime and live jobs 2026-11-30 or before `v2.5.0-rc.1`, whichever is first. No job has been run.

Security: authentication, sessions, rate limiting

- CAT-D9-SUSPEND (+ D9S-R3-1..4, D9SR3-F1/F2/F3/F4): admin suspension is a permanent lock and revokes sessions; NULL-safe `is_locked` reads; login/refresh non-loginable semantics; unknown/legacy-user login timing.
- CAT-LOGIN-LOCK-1, CAT-LOGIN-LOCK-2: login back-off redesigned; in-flight attempt cap, every evaluated attempt charged, owner success never writes the account scope; PostgreSQL-verified (both images).
- CAT-CHPW-RL-1, CAT-CHPW-RL-1-FU, CAT-CHPW-RL-2, PKGC-FU4-F2: change-password per-session failure budget and per-user ceiling, session revoke on change, AST wiring guards for the `/api/v1/auth` routes (unit class, in-memory counters per process).
- OPA-1..OPA-5, PKGC-FU4, CAT-OPDEC-A: Redis rate-limit per-limiter outage breaker with half-open single probe, per-tier Redis keys (auth 600 / default 2000 per minute), outage after startup falls back to the in-memory limiter; role 2 compared like every other role.
- CAT-LOGSHARE-TOK-1: log-share tokens are 32 random bytes, hashed at rest, shown once, uniform 404 on every failure; session-id hardening.
- CAT-JOB-404-1: a job id owned by another user returns the same 404 as a missing id; permission lookup runs before the job lookup.
- SEC-WS-1, SEC-WS-1-F3, SEC-WS-1 F4/F5/F6, SEC-WS-1R3, SEC-WS-1R3FU-1/2: `/ws` behind authentication with an Origin policy, post-upgrade auth recheck, audience-filtered broadcasts, nginx confs forward `$http_host` (httptest level; live client/nginx run owed).

Security: egress, error leakage, confinement

- CAT-SECQ1-A, CAT-SECQ1-B (W3), S1A3-1..4, OBF-3, PKGA-FU2, PKGA-FU2-F2: outbound address-class pinning; the cloud-metadata singleton addresses (including `fd20:ce::254`) are always refused, and SMB host vetting shares the netguard reserved ranges.
- SEC-DIAL-1, SEC-DIAL-1-FU: SMB/FTP/NFS storage hosts are vetted at create and pinned at dial; dial errors scrubbed.
- CAT-PXF23, CAT-PXF23-R, CAT-PXF23-R5, CAT-PXF23-R5B, PXF23-R5a/F4, CAT-R5-FU, CAT-R5FU-FU, CAT-WP02-ERRLEAK, SVC-PREEXIST-1: internal `err.Error()` text no longer reaches clients (fixed class text, request id).
- PX-F1..F23 (PX-F13/F17/F20-F23: unified log/panic redaction, custom Recovery, typed leak scanner, KnownSecrets), HANDLERS-RED-1: log redaction hardening.
- CAT-FS-SYMLINK-1: symlink confinement for local and NFS filesystem clients with a single confined copy path.
- CAT-SEC-CONTRIB-1: `.mailmap` maps the placeholder agent identity to the owner.

- CAT-RETEST-STALE-1: NFS export refuses `,` followed by `:` (second darwin server location); two stale tests fixed.

Storage connectors

- CAT-SMB-SUBDIR-1: Anton SMB N=3 live logs added (no negative control).
- CAT-SECQ2-WD-F1: live WebDAV reproduction, not reproduced (VERIFIED evidence, PROVISIONAL conclusion).

Installation wizard

- OBF-1, OBF-2, OBF-4, OBF-FU, CAT-OPB-FU, CAT-OPB-FU2, CAT-QA-SONAR-5: merge-never-overwrite of the config, symlink-resolved confinement (dangling links refused), probe temp files, `CONFIG_PATH` (wizard directory) vs `CATALOG_CONFIG_PATH` (app config file) docs, declared `file_create` template loaded.

Web

- CAT-UI-FAV-1, CAT-UI-FAV-1b, FAVR3-1/2, FAVR3R3FU: favourites open the right entity (`entity_id`/`entity_type`), optimistic update on live keys with rollback; live Playwright run owed.
- CAT-QA-SONAR-7-FU2, CAT-OPDEC-B: Enter auto-repeat guard, no block content in template buttons, unused `onActivateKey` removed.
- CAT-PREEXIST-7, CAT-PREEXIST-8, CAT-PREEXIST-9, PW-F1..F10 (CAT-PWF9): vitest alias fallback for dist-less `@vasic-digital/*` packages, jsdom Storage on Node 26.

Release tooling

- CAT-REL-CHECK-1, CAT-REL-CHECK-2, CAT-REL-CHECK-3: HEAD-snapshot release-consistency checker (502 tests; 236 mutants defined, but the full 236-mutant set has not been run end to end, per `docs/FOLLOW_UPS_NEXT_PHASE.md`), waivers; advisory for v2.4.3.
- CAT-WP03, CAT-WP03-MECH (WP03R3-F1..F7): `image_no_worse` comparator and `release_gate` scripts (11.4.293 / 11.4.298), gate-logic unit class, not wired into tagging or deploy.
- V250-GATES: v2.5.0 gate checklist, an UNREVIEWED draft (independent review owed).
- CAT-CONST-BUMP-1, CAT-UPSTREAMS-1: constitution bump (`helixconstitution-v73.3-397-g02c10935`), Codeberg upstream recipe.

Image, QA tooling, tests, docs

- CAT-IMG-SLIM-1: API image 746 MB to 307 MB via minimal ffmpeg (container class).
- CAT-PREEXIST-1..6, CAT-PREEXIST-10, CAT-PXF23 follow-ups: stale or flaky pre-existing test failures fixed (host-adaptive stress floor, nil-slice allowlist, sqlmock expectations, openapi-contract 404).
- CAT-WP10-TRIAGE, WP-10, WP10R4: follow-up triage document and generator (`docs/FOLLOW_UPS_TRIAGE_2026-11-12.md`).
- CONT-DENY-STRUCT (Containers `aa99d46`), BG-NASEMU-2026-11-13 (NAS emulator research and NE-3 seed, Containers `24ba32c`), CAT-DEVEMU (device-emulation plan), BG-OPQ-2026-11-13b (operator decisions record), CAT-QA-SONAR / CAT-SONAR-REGAUTH (Sonar registry-auth follow-ups), DOCS-ORPHANS-2026-11-13 (orphan reachability and PDF renderer), CAT-DOCS-README (DeepWiki badge).

REOPENED

- None recorded between `v2.4.2` and `main` `b43f5370`: no live rerun FAILed on a previously closed item. This is the absence of recorded failures, not proof that nothing regressed (the full-suite retest of the tag has not been run).

OVERDUE

- Carried, still overdue: the `[2.4.2]` and `[2.4.1]` verification jobs (full-suite retest of a tag, SonarQube run6 on a tag, 11.4.185 manual QA, live UI QA with Vision, Anton `Public/Testing` SMB runs, cover-art SSRF N>=3 production-client leg). No new job has an elapsed due date recorded.

Known failing, unconfirmed or not landed (from the 11.4.40 partial retest of `main` `3a33fb05`, CAT-RETEST-STALE-1, in `docs/FOLLOW_UPS_NEXT_PHASE.md`)

- Retest (scratch copy, PROVISIONAL): go build/vet rc 0; go test 5935 pass / 20 honest skip / 3 fail (two new stale tests fixed on `main`; the third was scratch pollution); catalog-web type-check pass, vitest 2796 pass.
- Pre-existing lint error: catalog-web lint 1 error + 84 warnings (`ExternalIntegrations.test.tsx:100` unnecessary semicolon, same line in v2.4.2).
- The `catalog-api/tests/automation` module fails with connection refused instead of an honest SKIP (same on v2.4.2).
- The catalog-web production build is UNCONFIRMED (offline npm cache lacks `@vasic-digital/*`; ENOTCACHED). `gofmt` lists 42 files (same on v2.4.2). `-race` (Alt-Svc Use race F-F) not run.
- Release checker: `scripts/release/check_release_consistency.sh --repo . --version 2.4.3 --prev-tag v2.4.2` (section `[2.4.3]`) returns PASS with only `unused_waivers=3` (version_ok=19, sha_ok=64, sha_fail=0, unlisted=0). The "known 4 findings" (sha_fail=1, no_manifest=1, unlisted=1, unused_waivers=3) come from checking the `[2.4.2]` section (`--section 2.4.2`, the cover-art evidence set) and are unchanged. The checker is advisory for v2.4.3 and blocking for v2.5.0.
- `scripts/anti-bluff-scan.sh` reports 4 `ASSERT_TAUTOLOGY` findings, all in third-party/hub code, none in first-party code (carried from the retest, unchanged).
- **CAT-NFS-EMU-1 was NOT landed** (R_max NO-GO on `feat/nfs-emulator`); successor **CAT-NFS-EMU-2** is open. Likewise not landed or still open: CAT-PREEXIST-9b (web load failures, UNREPRODUCED), D8-F1, D9-F1, SEC-WS-1 follow-ups, RS-1..RS-4 (minor, from CAT-RETEST-STALE-1). Items owed before v2.5.0 are in `docs/release/V2_5_0_GATE_CHECKLIST.md`.
- Synology SMB/FTP/NFS live tests remain SKIPPED (drives powered off).

Behaviour changes and upgrade notes (read before upgrading)

- **Job ids:** a conversion job owned by another user now returns 404, identical to a missing id (was distinguishable from a missing id).
- **Symlink confinement:** local and NFS filesystem roots refuse symlinks that escape the root. A per-root option `allow_symlink_escape` (default off) exists; it is not reachable from the DB row or config in this release (documented in `docs/security/PATH_CONFINEMENT.md`; UNCONFIRMED how an operator sets it).
- **Metadata addresses:** the cloud-metadata singletons (incl. `fd20:ce::254`) are always refused for storage roots and SMB hosts, with no allow-list. Storage hosts (SMB/FTP/NFS) are vetted at create and pinned at dial: an existing root pointing at a now-refused address will fail to connect.
- **NFS export:** an export string with `,` followed by `:` is refused (a second server location on darwin `mount_nfs`).
- **Redis rate limits:** per-tier keys (`auth` 600 / default 2000 per minute); an outage after startup falls back to the in-memory limiter; login/register stay on the in-memory 30/min limiter.
- **Login throttle:** a cap of in-flight password evaluations per account; every evaluated failed attempt is charged, also on an already blocked account; a successful owner login no longer writes the account throttle scope (throttle state is stored in the database; PostgreSQL-verified).
- **Change password:** failed current-password attempts are limited per session and per user (5 per 15 min); a password change revokes sessions (see CAT-CHPW-RL-1); the change-password counters are in memory per process.
- **Suspension:** an admin suspension is a permanent lock and revokes sessions (CAT-D9-SUSPEND).
- **Log shares:** tokens are new 32-byte random, hashed at rest, shown once; every failure returns the same 404; a JWT is required to create. Migration v28 retires existing share links (see the migrations bullet).
- **WebSocket:** `/ws` requires authentication and an Origin policy (host:port and scheme); deployments using the shipped nginx configs must pick up the updated confs (they forward `$http_host`).
- **Errors:** responses no longer include internal error text (fixed class text and a request id).
- **Login fails closed:** when the login throttle state cannot be read or written, login answers **503** `sign-in temporarily unavailable` (`ErrLoginThrottleUnavailable`, `handlers/auth_handler.go`) instead of letting the attempt through. While an account or address is throttled, login answers **429** (`too many failed sign-in attempts, try again later`).
- **Unlock of a suspended account:** the user unlock call answers **409** for a suspended account; only an administrator status change to active lifts a suspension (`handlers/user_handler.go`).
- **Schema migrations run on upgrade:** v27 (`approved_class` columns on `storage_roots` and `sync_endpoints`, CAT-SECQ1-A), v28 (retires every legacy plaintext log-share token: the share row is

deactivated and its token overwritten, so **existing log-share links stop working and the creator must re-share**, CAT-LOGSHARE-TOK-1) and v29 (creates the `login_throttle` table). **Rollback:** the in-process migration runner has only `Up` steps (`catalog-api/database/migrations.go`, `Migration{Version, Name, Up}`), so a downgrade is NOT supported; back the database up before upgrading and restore it to go back. Whether a v2.4.2 binary tolerates the v27/v29 schema (extra columns and table) is UNCONFIRMED, and v28 cannot be undone.
- **Roles:** role 2 is compared against the caller like any other role.
- **Image:** the API image is 307 MB (was 746 MB) with a minimal ffmpeg; **conversions to ogg and m4a now drop embedded cover art**.
- **Wizard:** the config is merged, never overwritten; `CONFIG_PATH` is the wizard directory and `CATALOG_CONFIG_PATH` the app config file.
- The behaviour change under `Security (outbound address classes, CAT-SECQ1-A)` below is new in this release. The `TRUSTED_PROXIES` changes (including the compose network upgrade step) are not new: they shipped in `v2.4.0`.

New in 2.4.3, from the former `[Unreleased]` section (checked with `git grep` on the earlier tags)

Security (outbound address classes, CAT-SECQ1-A; PROVISIONAL)

- **Behaviour change: storage roots (WebDAV, S3) can no longer reach the server's own interface addresses** (for example its LAN address) unless allow-listed (`CATALOGIZER_OUTBOUND_ALLOW_CIDRS=<ip>/32`). Other LAN addresses keep working.
- Operator transports pin themselves to the address class of their first connection (a root on a public address cannot be redirected into the LAN, also inside gowebdav); a dial-time check re-validates the connected address; 168.63.129.16 is refused; invalid or over-broad (`/0`…`/7`, also IPv4-mapped) allow-list entries are logged and ignored unless `CATALOGIZER_OUTBOUND_ALLOW_BROAD=1`; non-ASCII and numeric host spellings are refused on all paths. Details: `docs/ENV_VARIABLES.md`, `docs/OUTBOUND_HTTP_CLIENTS.md`.

Already shipped earlier (listed for context, NOT new in 2.4.3)

The items below were in the former `[Unreleased]` section but are already contained in earlier tags (checked with `git tag --contains` on their commits and `git grep` on `v2.4.0`, `v2.4.1`, `v2.4.2`): TRUSTED_PROXIES hardening (commit `8c1fb3339`, first tag `v2.4.0`; `TRUSTED_PROXIES_ALLOW_AUTO` is in `v2.4.0`'s `.env.example`), FTP `CopyFile` with the `.ftpcopy-<hex>.part` temp file and `renameGraceAfterCancel` (first tag `v2.4.0`), Spec Kit constitution 2.5.0 and `docs/GOVERNANCE.md` (in `v2.4.0`), and the old `Fixed` items such as the challenge framework, Android TV lint and the axios SSRF fix (first tag `v2.4.0`). They are kept verbatim for context and are not part of the v2.4.3 list or counts.

Security (TRUSTED_PROXIES)

- **`TRUSTED_PROXIES=auto` is deprecated and refused in release mode** (CAT-TRUSTEDPROXIES-AUTO-1): it trusts all RFC-1918/ULA ranges, so a client inside one of them could send `X-Forwarded-For: 9.9.9.9` and have the proxy append its own address, making `ClientIP()` 9.9.9.9 (login rate-limit bypass; gin skips trusted entries from the right and has no "trust only the direct hop" mode). With `GIN_MODE=release`, `auto` now fails unless `TRUSTED_PROXIES_ALLOW_AUTO=true`; a startup warning is logged whenever `auto` is used. A rejected or invalid `TRUSTED_PROXIES` now **fails closed** (no proxy trusted): previously a refused `auto` left gin's trust-everything default in place, and an invalid CIDR list left whatever gin had applied before the error (possibly a partial list). **Behaviour change:** deployments relying on `auto` in release mode must list explicit proxy CIDRs (or set the acknowledgement). `catalog-api/.env.example` no longer enables `auto`.
- **Production compose files now set `TRUSTED_PROXIES`** (CAT-TRUSTEDPROXIES-PROD-1): `docker-compose.yml` (nginx, `production` profile) and `deployment/docker-compose.yml` (`web`) pin the proxy to a fixed address on a fixed-subnet network (`172.28.0.10` / `172.29.0.10`) and the API trusts exactly that `/32`; previously every client behind nginx shared one login rate-limit bucket. Dynamic containers are allocated only from the upper half of each subnet (`ip_range` `172.28.0.128/25` / `172.29.0.128/25`), so the pinned address cannot be taken by another container. Overrides: `CATALOGIZER_SUBNET`, `CATALOGIZER_IP_RANGE`, `NGINX_IP` (root file) and `DOCKER_SUBNET`, `DOCKER_IP_RANGE`, `WEB_IP` (deployment file); when you change the address also set `TRUSTED_PROXIES`. A subnet that overlaps a host network fails `up` with a "Pool overlaps"/address-in-use error: pick another subnet via those variables.

- **Upgrade / migration (existing installs):** compose reuses an existing network of the same name and ignores new ipam settings, so the pinned address would fail or be ignored. Before the first up of this version run `compose down`: for the root file the network is project-scoped (`<project>_catalogizer-network`) and `compose down` removes it (do not remove a bare `catalogizer-network`, it belongs to another project). The `deployment` file's default network name changed from the fixed `catalogizer-network` to `catalogizer-frontdoor-net` (override `DOCKER_NETWORK`) so it does not collide with an older network; remove the old `catalogizer-network` only if no other stack uses it.
- `deployment/docker-compose.yml` `web` now sets `API_UPSTREAM: catalogizer-server:8080`. The web image's nginx template (`catalog-web/nginx.conf.template`, rendered by the official nginx entrypoint, `NGINX_ENVSUBST_FILTER=^API_`) proxies to `API_UPSTREAM`, whose default `host.containers.internal:8080` goes via the host and would hide the pinned web address from the API. Its `/ws` location now forwards `X-Real-IP`/`X-Forwarded-For` too, and `config/nginx.conf` `/health` does the same (a test scans every `proxy_pass` location).
- A startup warning is logged when `TRUSTED_PROXIES` contains `0.0.0.0/0` or `::/0`.
- Verification: `ip_range` reaching network creation was confirmed with a throwaway podman-compose project (pinned `.10` outside the range, a dynamic container got `.129`). Not verified live: the real compose stacks were only rendered (`podman-compose config`), not started; that the published `catalogizer/web` image is built from `catalog-web/Dockerfile` is assumed.
- Tests pin every `auto` range with both edges, the forgery hazard, release-mode refusal, fail-closed behaviour, and the compose-to-policy link (CAT-TRUSTEDPROXIES-FU-1).

Governance

- **Spec Kit constitution 2.5.0** (2026-10-21): single-source flat layout (owner mandate: no nested submodule chains); canon pin moved `4bcb512` → `a3d80ce` (canon branch `feat/hub-engines-single-source` merged and pushed to canon `main`) and then to its follow-up `5f8503b` (pushed to canon `main`); `llmctl` `f42bad6` (cleaned, `CM-LLMCTL-SUBMODULE-NONRECURSIVE` PASS), root `helix_qa` `ad8b12b`; `claude_toolkit` `1f6dad3` (cleaned: nests only the third-party Go toolchain, ships `helix-deps.yaml`; at `a3d80ce` it was `223c702` with both gates RED); `CM-HUB-ENGINE-NO-OWNORG-NESTING`, `CM-HELIX-DEPS-MANIFEST-PRESENT` and `scripts/verify_helix_deps_manifests.sh` PASS (pass 54 / fail 0); index scope re-rendered from DATA (`derive_scope.sh`, `scope_to_lumen_json.py`, `scope_render.py`, `scope_drift_check.sh --regen`), drift check passes; root `helix-deps.yaml` refs re-synced to the staged gitlinks; `scripts/safe_submodule_init.sh` warns about leftover directories of dropped gitlinks; safe init through `scripts/safe_submodule_init.sh`; 27 flat tool submodules; Known Conflicts items 21(d), 25 to 27 and 29 updated (27 and 29 RESOLVED), items 30 to 32 added. Earlier in the day, **2.4.0**: canon pin moved `94b8836` → `4bcb512`; new section "Constitution Hub Engines" binding the vendored `llmctl`, `claude_toolkit` and `open_design` (rules HE-1 to HE-8, appendix Part 3); Known Conflicts items 21(c)/(d) corrected and items 25 to 29 added (29: code-index scope data) (canon's `CM-LLMCTL-SUBMODULE-NONRECURSIVE` gate fails at the new pin; `claude_toolkit` and `open_design` are not in canon's manifest). See `docs/GOVERNANCE.md`.
- Documentation: safe, non-recursive submodule initialisation through `constitution/` in `README.md`, `GETTING_STARTED.md`, `docs/DEVELOPER_GUIDE.md` and `docs/SUBMODULE_DEPENDENCIES.md`; new `docs/GOVERNANCE.md`.

Changed (FTP CopyFile, filesystem package)

- **FTP `CopyFile` no longer deletes or overwrites the destination in place** (`catalog-api/filesystem/ftp_client.go`). The data is now stored under a temp name beside the destination, `.<base>.ftpcopy-<16 hex>.part` (base cut to 200 bytes on a rune boundary, so the whole name stays under NAME_MAX), and renamed onto the destination (RNFR/RNTO) only after the source transfer is confirmed. **Behaviour change:** a server that refuses rename onto an existing file (some proftpd/pure-ftpd configurations) now makes every copy onto an existing destination fail, with the destination left unchanged and the temp removed; previously the destination was overwritten in place (plain STOR), which such servers allowed. Servers with MoveFile-style rename semantics (possibly Windows/IIS FTP, UNCONFIRMED) may be affected as well. A failed or cancelled copy never touches a pre-existing destination.
- **Orphan reporting contract:** if the temp cannot be removed after a failure or cancellation, the returned error names it (`temporary file <path> may remain on the server`; typed `*orphanError`, reachable with `errors.As`, also on the cancel path) and a log line is written. Whether a failed cleanup DELE means "the temp never existed" is decided from the 550 reply text: only a text naming a missing file/directory (no such

file, no such directory, not found, does not exist) counts, and any mention of permission, privilege, denial or read-only vetoes it (`550 No such privilege` and `550 File not found or permission denied` are reported as possible orphans). The heuristic is imperfect (servers word it differently, localised servers differ); an unrecognised or mixed wording is reported as a possible orphan rather than ignored, so a miss errs towards reporting.
- **Known limits:** once the transfer is confirmed the cancel watcher is disarmed, so a cancel during the final rename does not close the connection at once (a responsive server still commits). A rename that then gets no answer is cut off after `renameGraceAfterCancel` (5s after the cancel): the session is closed and the error says the rename "may or may not have been applied". A connection that dies during the rename is reported the same way, not as "left unchanged". The single-session spool fallback has no such cut-off. Evidence is unit-class against a fixture server; no live-NAS proof.
- **Scanner:** the catalogue scanner (`internal/services/generic_scanner.go`, FTP storage only) skips *files* named exactly `.<anything>.ftpcopy-<16 lowercase hex>.part` (in-flight or stale `CopyFile` temps; the pattern also matches names containing a newline); a user's own look-alike names such as `.x.part` are still catalogued. `FTPClient.ListDirectory` itself reports every entry, so callers that list, move and remove a directory (`moveDirectory` in `internal/services/protocol_handlers.go`) see a stale temp instead of failing the final remove with a confusing "not empty". Stale temps left by a crashed copy are not removed automatically.
- The single-session fallback spool directory is configurable (`FTPConfig.SpoolDir`, default the OS temp dir); free space is computed from `f_frsize` on linux and `f_bsize` on darwin/freebsd (build-tag split, so darwin builds); other platforms report free space as unknown. A negative `f_bavail` counts as 0.
- Evidence class: unit tests against a hand-written FTP responder; no live-NAS run yet (owed).

Fixed

- **Challenge framework**: `RunSequence` now performs Kahn topological sort on dependencies, fixing `RunByCategory` alphabetical-order failures
- **Challenge streaming**: `RunAll` and `RunByCategory` handlers support NDJSON streaming mode (`?stream=true`) to eliminate tens-of-MB buffer blocking
- **Challenge timeout**: per-challenge timeout reduced from 72h to 30min as a hard ceiling distinct from stale-progress detection
- **database-connectivity hang**: `DatabaseConnectivityChallenge` now implements progress reporting, enabling 5-min stale detection
- **Android TV lint**: 49 pre-existing lint errors fixed via `@SuppressLint` for legitimate `androidx.tvprovider` and Media3 API usage
- **Android TV package**: challenge config corrected from `com.vasic.catalogizer.tv` to `com.catalogizer.androidtv`
- **Security**: axios SSRF vulnerability patched in `Catalogizer-API-Client-TS`
- **PlaybackTracker**: added `ensureActive()` and re-throw `CancellationException` to prevent coroutine leaks
- **PlaybackTrackerTest**: stabilized by removing shared `TestScope`, eliminating `UncompletedCoroutinesError`